An Empirical Study of AI Bill of Materials Completeness in Hugging Face AI Models

Md Erfan • Ahmed Ryan • Md Rayhanur Rahman

Department of Computer Science · The University of Alabama

Software Security Course — Research Paper Presentation

Presenter

Md Erfan

Outline

1. Motivation & Software Security Problem
2. Background: SBOM, AIBOM & Hugging Face
3. Research Questions & Study Design
4. Methodology: AIBOM Generation and Scoring
5. Results: Completeness, Fields & Patterns
6. Security Implications, Limitations & Discussion

Motivation: AI Models Are Software Dependencies

- Software projects increasingly integrate pretrained models from public hubs.
- A model may depend on training data, licenses, configurations, and external code.
- Downstream developers need provenance and documentation to assess reuse risks.

Without transparent documentation

Unclear licensing, dataset provenance, model limitations, and traceability.

With an AIBOM

Machine-readable inventory of the model and available supply-chain information.

Security question: Can we trust what the AIBOM actually tells us?

Why Documentation Completeness Matters for Security

Provenance

Where did the model, datasets, and derived weights originate?

Licensing & reuse

Can teams identify applicable terms before distribution or deployment?

Risk assessment

Are safety, limitations, and responsible-use disclosures accessible?

Auditability

Can an investigator trace model versions and external references?

An AIBOM supports security review; its existence alone does not establish model safety.

Key Concepts

SBOM

Software Bill of Materials: machine-readable inventory of software components and dependencies.

AIBOM

AI Bill of Materials: extends inventory information to model identity, data, licenses, and AI-specific documentation.

Model card

Documentation describing a model's purpose, intended uses, evaluations, limitations, and other details.

CycloneDX

Standard format for expressing BOM metadata and structured component information.

A model card is a source of information; an AIBOM is its structured representation.

From Hugging Face Repository to AIBOM

HF Model Repository

README · metadata
config · licenses

→

OWASP AIBOM Generator

Extract and map
available fields

→

CycloneDX AIBOM

JSON fields and
completeness score

Main challenge Missing AIBOM information can reflect missing source data or generator extraction limits.

Research Gap & Goal

Prior evidence

Research has studied model cards, metadata, model reuse, SBOMs, and emerging AIBOM tools.

Gap

Large-scale field-level evidence about completeness of generated AIBOMs remains limited.

Study goal Characterize AIBOM completeness and documentation gaps across public Hugging Face models.

Research Questions

RQ1

Overall completeness

How complete are generated AIBOMs at scale?

RQ2

Field availability

Which AIBOM fields are present or missing most often?

RQ3

Coverage variation

How does documentation vary across repository and model characteristics?

Dataset Collection and Filtering

2,942,466
HF model records
Initial public snapshot

→

>100
Download threshold
Focus on observed reuse

→

97,940
Generated AIBOMs
Analyzed artifacts

Scope of the evidence

Results describe generated AIBOMs for reused public HF models, not every hosted or private model.

Filtering helps computational feasibility but can limit external validity.

OWASP AIBOM Completeness Score

20 pts	20 pts	20 pts	30 pts	10 pts
Required fields	Metadata	Component basic	Model card	External references

Overall score = weighted category coverage × penalty factor

Important interpretation: this score evaluates field coverage, not full semantic quality or model safety.

Study Workflow

1. Collect HF metadata
2. Filter >100 downloads
3. Generate CycloneDX AIBOMs
4. Extract scores and fields
5. Compare groups and patterns

Analysis levels: overall score • category • individual field • repository characteristics

RQ1: AIBOM Completeness Is Moderate

54.31

Mean score

out of 100

54.10

Median score

out of 100

46.60–68.70

Observed range

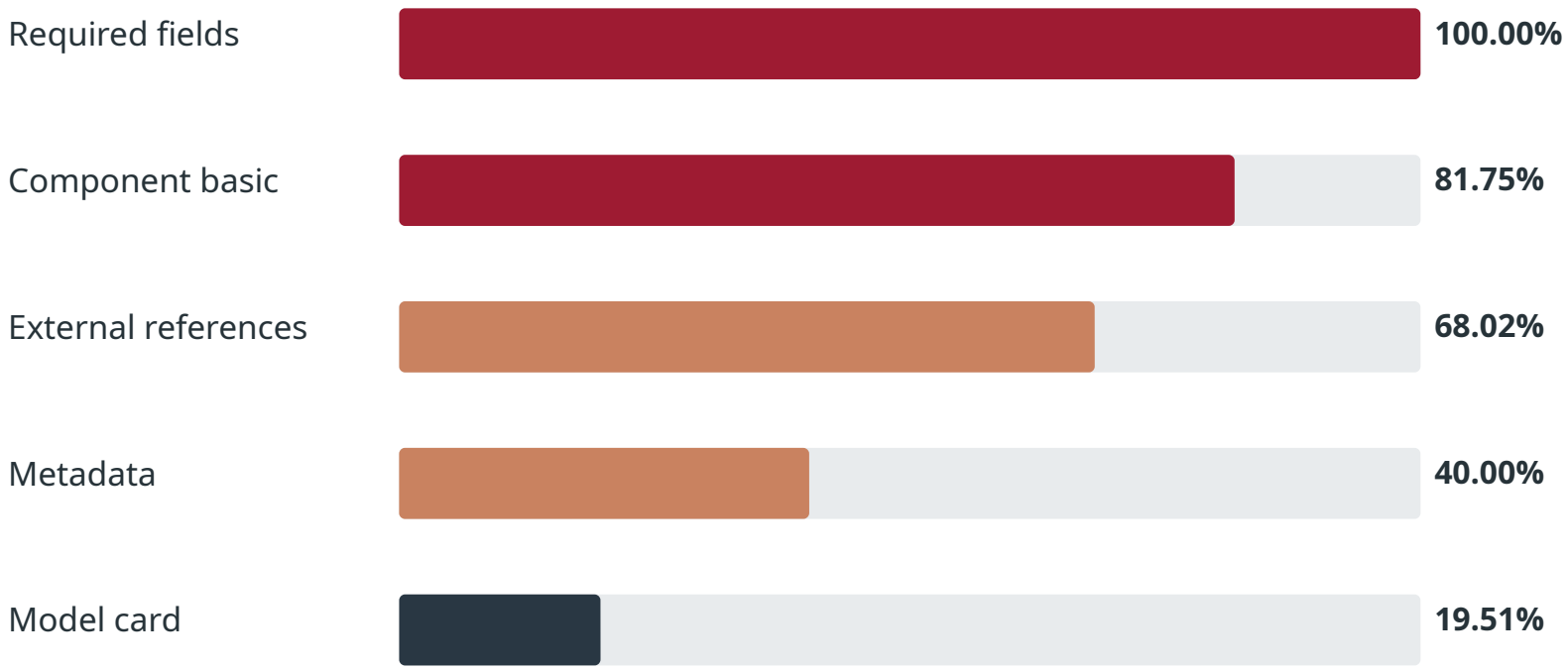
minimum to maximum

Main finding

Generated AIBOMs are moderately complete, but remain far from comprehensive AI-specific transparency.

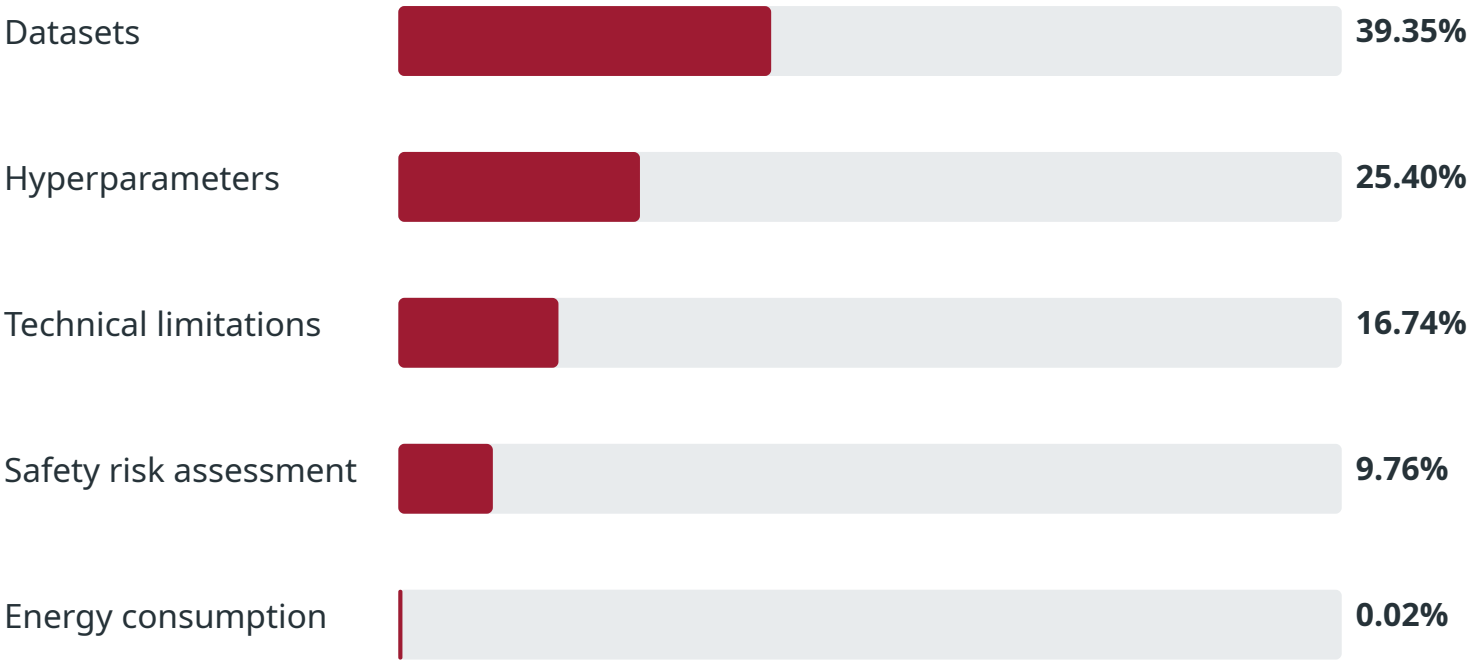
Based on 97,940 generated AIBOM artifacts (paper Table I).

RQ1: Strong Structure, Weak Model Cards



Model-card documentation is the weakest of the five completeness categories.

RQ2: Critical AI-Specific Fields Are Rare



Ethical considerations, intended use, and model explainability were absent in parsed AIBOMs.

RQ2: Present Does Not Mean Informative

99.99%

Description present

AIBOM field coverage

≠

0.22%

Meaningful description

211 of 97,940 AIBOMs

Syntactic completeness

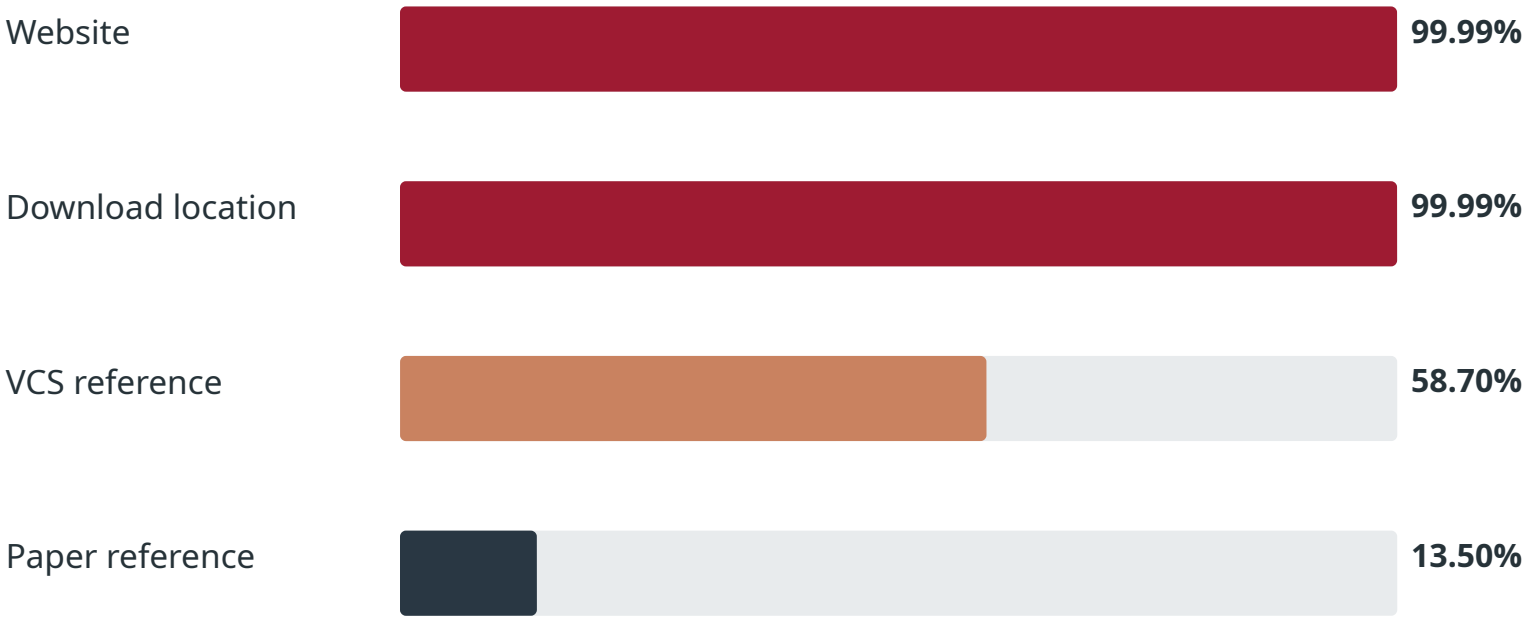
A field is populated, potentially with a placeholder.

Semantic usefulness

The content supports informed model reuse or review.

The paper separately checked descriptions for substantive content.

RQ2: External References Are Uneven



Basic repository links are common; richer source and scholarly traceability is less common.

RQ3: Paper + Dataset Signals Align with Stronger Coverage

Both paper and dataset

99.59%

VCS coverage

49.04%

Technical limitations

Neither paper nor dataset

55.04%

VCS coverage

7.16%

Technical limitations

Associations, not causation: documentation signals tend to co-occur.

Implications for Software Security

For model publishers

Publish structured licenses, datasets, intended uses, limitations, and source references.

For downstream developers

Inspect category- and field-level gaps before selecting or deploying a model.

For AIBOM tool builders

Make extraction gaps visible and validate references and field quality.

For security analysts

Treat an AIBOM as an inventory and evidence source—not proof of safety.

Security takeaway: transparency depends on both source documentation and extraction.

Limitations & Threats to Validity

Construct validity

OWASP scoring mostly captures presence; non-informative values can still count.

Internal validity

Generator extraction, HF API behavior, and parsing can affect field coverage.

External validity

Models with >100 downloads on public HF; results do not cover all AI ecosystems.

Interpretation

Observed associations across model groups are not causal findings.

Course discussion: What independent validation would strengthen the evidence?

Beyond Field Presence: Deeper Security Validation

Discussion prompts extending beyond the empirical results in the paper

Standards conformance	Does serialNumber follow UUID syntax? Does BOM version meet schema constraints?
Source vs. extraction	Is a missing dataset truly absent or missed by the generator?
Semantic quality	Is a description informative? Is a paper link truly a paper?
Provenance and consistency	Do license, model identity, version, and referenced code agree?

These are proposed follow-up assessments, not results established by the paper.

Three Challenges Raised During Peer Review

Post-submission feedback — methodological lessons for software security research

1

Construct validity

Is a missing field absent at the HF source, or simply overlooked by the generator?

2

Semantic depth

Field presence does not establish informative descriptions, trustworthy paper links, or usable licenses.

3

Robustness and generalizability

Do fixed weights, the >100-download filter, and task imbalance influence conclusions?

Key distinction: reported paper results versus proposed follow-up validation.

Source: ICSE 2027 reviewer comments and author rebuttal; not additional empirical findings.

Validation Plan: Repository vs. Extraction Gaps

Planned follow-up to determine why an AIBOM field is missing

HF source
README, YAML, configs, linked resources

→

Generator
Parsing and field mapping

→

AIBOM output
CycloneDX field/value

Four evidence-grounded field labels

Present in AIBOM
Mapped field is available

Extraction missing
Source evidence exists, output omits it

Repository missing
No relevant source evidence found

Unclear
Evidence insufficient or conflicting

Proposed checks: 100 sampled source comparisons; teacher–judge LLM pipeline; sanity and agreement checks.

Beyond Presence: A Field-Quality Rubric

Proposed semantic evaluation — distinct from the paper's original presence statistics

L0 Missing / invalid	No usable information, invalid value, or placeholder.
L1 Generic	Broad claim without task-specific detail or supporting evidence.
L2 Specific	Meaningful model-specific content, but evidence remains incomplete.
L3 Evidence-backed	Specific, traceable, consistent, and verifiable information.

Examples of deeper validation

paper

Preprint vs. peer-reviewed; exact model vs. base-model paper

datasets

Source link, dataset role, version, and traceability

licenses

Declared identifier, permissions, and conflicting terms

Robustness Checks and Security Implications

Planned follow-up analyses motivated by reviewer feedback

Scoring sensitivity Compare OWASP weights/penalties with equal-category and no-penalty alternatives.

Sample sensitivity Test alternative download thresholds and report task-stratified coverage.

Confounding factors Compare task, model family, popularity, base model, and derived/quantized variants.

Reproducibility Record the HF snapshot date, tool version, and source-to-output validation evidence.

Security lesson: a reported completeness score is not proof of standards compliance or trustworthiness.

Conclusion & Key Takeaways

1. **Scale** — 97,940 generated AIBOMs analyzed from public HF models.
2. **Completeness** — Mean 54.31/100; required fields 100%, model-card category 19.51%.
3. **Transparency** — Datasets, limitations, safety disclosures, and meaningful descriptions remain sparse.
4. **Practice** — Validate source evidence and field content before relying on an AIBOM.

Main message: structural coverage is not the same as usable AI supply-chain transparency.

Key References & Research Artifact

Paper	Erfan, Ryan, and Rahman, “An Empirical Study of AI Bill of Materials Completeness in Hugging Face AI Models.”
Generator	OWASP GenAI Security Project, AIBOM Generator.
Standard	CycloneDX specification: AI/ML model-card and SBOM fields.
Artifact	https://figshare.com/s/185c21d7bf411fa4b952

Source: attached AIBOM paper; visualization adapted from the supplied ICMLA slide style.

Thank You — Questions?

Can we rely on a “complete” AIBOM without verifying its contents?

Final takeaway

AIBOMs can improve AI supply-chain transparency, but field presence does not guarantee informative or trustworthy documentation.

Md Erfan

Department of Computer Science · The University of Alabama